01 / DER VORFALL IM OKTOBER 2026

PHP2Shell: Angriff auf Firewalls

Aus Sicht eines IT-Teams, nachgestellt

Unsere Firewall soll das Netz schützen. Jetzt nutzen Angreifer sie als Zugang ins Unternehmen.

Fehler in PHP erlauben fremde Codeausführung auf der Verwaltungsoberfläche.

25

Firewall- und Managementserver kompromittiert

Palo Alto Networks PAN-OS

Der konkrete Schaden

Zugangsdaten gestohlen.
Internes Netz ausgekundschaftet.

Fehlerbehandlung hinterlässt ungültigen Zustand

Fehlerbild

Belegt

Manipulierte Anfragen ermöglichen fremde Codeausführung in der PHP-Laufzeit.

Technische Ursache

Belegt

CVE-2026-109618

Speichermangel unterbricht die Initialisierung. Die Bereinigung nutzt unvollständigen Zustand.

CVE-2026-109619

Ein Worker behält Zeiger auf freigegebenen Zustand und nutzt sie im Folge-Request.

Organisation

Vermutung

Abbruchpfade und wiederverwendete Worker könnten zu wenig Testpriorität erhalten haben. Die interne QS-Praxis ist unbekannt.

> **ISO/IEC 25010:2023 · Sicherheit**
> Verletzte Vertraulichkeit und Integrität

Eine Testkampagne für erzwungene Speicherfehler

Fault-Injection im Request-Lebenszyklus

Meine Rolle: QS der PHP-Laufzeit vor Release, mit Zugriff auf instrumentierten nativen Code.

01 Im PHP-Allocator systematisch echte Speicherfehler auslösen.

02 Bereinigung und frühe Folgeanfrage im weiterlebenden Worker prüfen.

03 Ungültige Zugriffe und verbleibende Request-Zeiger prüfen.

Die Tests können ungültigen Zustand vor Release aufdecken, auch über Anfragegrenzen hinweg.

Sie benötigen keinen bekannten Exploit.

Freigabekriterium: Kein ungültiger Speicherzugriff in den geprüften Fehlerpfaden. Jeder Fund blockiert das Release bis zur Korrektur.

Verbleibende Risiken Begrenzte Pfad- und Konfigurationsabdeckung. Kein sicherer Fund aller Varianten. Die separate Kernel-Lücke bleibt bestehen.